LEXIGRID

Security Operations Handbook

Version 5.54.15 | Reviewed 2026-11-11

Shahryar Jahangir, Aniza Inc.

Procedures, examples, verification and operational limits. Complete commissioning on your deployment before serving customer traffic. Sample values are fictional; original keys and data must be preserved.

Contents

Security operations procedures 3

Scope and evidence . . . 3
Access review and negative tests . . . 3
Authentication and session incidents . . . 3
Cryptographic evidence handling . . . 3
Audit integrity and independent retention . . . 4
Logging and investigation . . . 4
AI governance and provenance . . . 4
Import and standards review . . . 4
Notification and incident recovery . . . 4
Qualification gates . . . 5
Local authenticator policy and optional setup . . . 5
Dedicated PostgreSQL identities . . . 5
AI adoption controls . . . 6

LexiGrid Enterprise Integration and Deployment Guide 6

SAML 2.0 . . . 6
Vault Transit encryption . . . 6
WORM audit checkpoints . . . 6
Deployment . . . 7
Administration and GUI . . . 7

LexiGrid Logging Configuration 7

Example . . . 7
Correlated requests and import outcomes . . . 8

Security operations procedures

Scope and evidence

Use this handbook with the access-control, provider and recovery procedures. Local tests verify specific application controls; they do not establish compliance certification or successful customer infrastructure integration. Record the exact tenant, actor, release, time and observed result for each review, without secrets or bulk tenant content.

Access review and negative tests

1. Inventory platform_admin, tenant_admin, risk_manager, risk_editor, risk_viewer and auditor assignments against job responsibilities.

2. Confirm that each active account belongs to the intended tenant and each federation account is explicitly bound to its immutable external identity.

3. Test a permitted operation and a denied lower-role operation using designated test accounts. UI visibility is not an authorization boundary.

4. Attempt a foreign-tenant object read/import/download with an authenticated test identity. The API must deny it without contacting an evidence provider for an inaccessible record.

5. Review privileged provisioning/binding/password changes and the committed audit actor. Contact labels and notification recipients must not grant roles.

Production PostgreSQL must run as lexigrid_runtime with forced RLS, no owner/superuser/bypass privilege and no runtime update/delete on audit/workflow decision history. The database role is a defense layer, not a substitute for API permission checks.

Authentication and session incidents

Confirm selected tenant, active account, issuer/subject binding, state/nonce/request correlation and MFA assertion. OIDC email/UPN is not an authorization identifier. SAML must validate signatures, issuer, audience, recipient/time and request binding before reading its MFA context. Both providers may be enabled together, but their real policies must be independently qualified.

Required-MFA enrollment tokens cannot access normal business APIs. TOTP counters are consumed atomically and cannot be reused concurrently. A user may revoke all sessions; an authorized owner administrator may recover credentials/bindings using the documented CLI procedure. Never request MFA seeds, tokens or original key values in an incident ticket.

Cryptographic evidence handling

The configured write provider must be exactly local, vault or conjur. Explicit invalid settings fail closed before bootstrap. Conjur supplies versioned keys for local AES-GCM; it is not an HSM. Local legacy base64/hex representations must retain the same original key bytes. Existing evidence is decoded from its envelope and original key material.

Failed encryption creates no evidence or successful upload event. Provider outages/configuration/key-access failures return controlled 503; malformed envelope, local/Conjur authentication or content hash failures return 409. A remote generic decrypt rejection is not proof of corruption. Preserve stored bytes and key history while investigating.

For an integrity incident, retain a private snapshot, source record identifier, expected hash and sanitized error. Check provider access and original keys before attempting recovery. Do not overwrite a record with a new upload merely to clear the error. Evidence metadata available to AI does not mean attachment contents were automatically read.

Audit integrity and independent retention

Runtime PostgreSQL cannot mutate existing audit or workflow decision records. HMAC verifies signed row content; it cannot independently prove that an entire row was never deleted. Historical unsigned rows must not be presented as signed.

Use a tenant-scoped audit checkpoint for restricted RLS roles. An unscoped export under RLS can be misleadingly empty, so explicit scope is mandatory. Keep the independent anchor HMAC key distinct from database/application secrets. Checkpoint files are created privately. Verify checkpoint digest/sequence with independently controlled evidence where required.

WORM publication writes a checkpoint, reads the specific version back, compares its hash and confirms Compliance retention. Actual Object Lock enforcement, retention administration and independent credentials must be qualified against the chosen storage. The application does not automatically schedule an independent retention service or certify a bucket.

Logging and investigation

System logs record startup/shutdown/request outcomes and bounded error classes. Operations logs report committed business actions; authentication failures are recorded without credentials. Invalid logging configuration prevents startup. Syslog forwarding is best effort, with verified TLS preferred for transport.

Correlate the request path, timestamp, actor/tenant and audit object. Avoid full SQL errors, environment dumps, model output or provider response bodies in tickets. User-entered business details can be sensitive even when secret-like keys are redacted. Apply retention/access control to logs and backups as well as the database.

AI governance and provenance

Confirm provider/model/endpoint and approved data classes. Local-only controls plus network egress enforcement must be verified; a local hostname setting alone does not certify disconnection. Cloud use needs explicit configuration and authorization for the transmitted data.

The official risk score remains a human decision. A proposal's verified provenance means its saved payload matches the endpoint's recorded digest; it does not mean the model is correct. Generic Enterprise IRM edits cannot forge proposal payloads. Legacy unverified proposals remain available with their caveat. Review control tests, findings, gaps, answered questions and exact evaluated input before deciding.

Import and standards review

CSV/document import must remain tenant-scoped and atomic. Unchecked candidates are not approved; changing file/type invalidates the preview. Source hash is provenance, not certification of a standard's authenticity or legal interpretation. Keep authorized source copies separately. Scans require OCR; unknown layouts require human review.

For ISO/IEC 27001:2022, separate management clauses and Annex A controls. An organization policy must not be inferred from a standards cover/copyright page. Do not upload licensed/confidential text to external extraction services without authorization. The product's extraction is local.

Notification and incident recovery

SMTP acceptance, provider delivery/bounce and explicit user acknowledgement are distinct. Signed callbacks bind timestamp, tenant and notification. Dead-letter recovery requires an authorized actor, reason and current attempt count. Leases prevent stale completion but cannot prevent every duplicate after remote acceptance and process loss.

If a worker crashes, preserve the queue/audit history, allow lease recovery and inspect gateway records before retrying manually. Do not reset attempts or delete failed rows as cleanup. Verify recipient opt-in and intended tenant before a test send.

Qualification gates

Maintain open evidence for real IdP/MFA round trips, KMS rotation/key recovery, independent WORM retention, SIEM/TLS, Windows native, disconnected artifacts and HA/failover. Repeat access/recovery tests when relevant identity, schema, key or deployment topology changes. Document the practical limit of each local test instead of claiming production readiness from a passing mock.

Local authenticator policy and optional setup

Set LEXIGRID_REQUIRE_LOCAL_MFA=0 to allow password sign-in before enrollment; set it to 1 to require local enrollment. Without this variable, the legacy LEXIGRID_REQUIRE_MFA value is used for local accounts. LEXIGRID_REQUIRE_MFA continues to enforce configured OIDC/SAML MFA policy independently. Optional enrollment does not disable a factor that has already been enabled.

Users may open Security > Add authenticator later, scan the locally generated QR code, and enter the app's current six digits. Reopening pending setup retains its key. Successful confirmation issues a new session and revokes older sessions, avoiding an immediate attempt to reuse the consumed code. Cancel setup discards only pending enrollment. Keep original encryption keys and phone/server clocks synchronized.

Dedicated PostgreSQL identities

Database identities must be explicit and separate from an operator's operating-system login. Native installation defaults to `lexigrid_owner` for privileged setup, and the application uses restricted `lexigrid_runtime` credentials after provisioning. A DBA may choose a dedicated maintenance account such as `lexiadmin` using `--pg-user lexiadmin`; create it under the deployment's approved database administration procedure. Migration-created roles use fixed product names, never the current OS username. The installer does not automatically create a personal or privileged account named after the person running it. SQLite uses a database file and has no database login.

For a supplied PostgreSQL URL, put the intended account explicitly before `@`, for example `postgresql+psycopg://lexigrid_runtime@db.example.invalid/lexigrid` (supply credentials through the approved configuration or secret mechanism). URLs such as `postgresql:///lexigrid` and URLs with `user` / `username` query overrides are rejected before a connection is attempted. Installation, application startup, maintenance, runtime provisioning, diagnostics and the backup script apply the same check. The operating-system username, PGUSER and database-service defaults cannot supply an omitted identity.

Before upgrading an existing PostgreSQL deployment with an implicit username URL, have the DBA supply the approved dedicated account explicitly. Do not rename roles, reset passwords, replace encryption keys or recreate databases simply to satisfy this setting. Existing explicit connections, original credentials and data are retained. Audit records may still identify the actual OS operator separately from the database role.

AI adoption controls

AI proposals cannot automatically change official ratings. The risk panel offers explicit Keep/Apply choices, with a second confirmation before Apply. Adoption uses existing risk-edit authorization, tenant scope, saved output/input provenance, current evidence and risk/proposal versions. Existing formal workflows must produce an exact content-bound accepted approval; it is consumed once. Generic Enterprise transitions cannot bypass this path. Adoption, the residual assessment, risk update, audit and notification queue commit atomically. A failed or duplicate action does not leave a partial adoption. Current-exposure reductions require cited support; planned controls, file metadata, attestations and future treatment promises do not suffice. Review the AI guide for the current 90-day evidence window and human-assessment alternative.

Timestamp verification converts PostgreSQL-returned offsets to UTC before recomputing existing UTC audit signatures. Stored signatures and append-only history are retained.

LexiGrid Enterprise Integration and Deployment Guide

Author: Shahryar Jahangir, Aniza Inc. - reviewed November 5, 2026

SAML 2.0

Configure `LEXIGRID_SAML_SP_ENTITY_ID`, `LEXIGRID_SAML_ACS_URL` (public HTTPS `/api/auth/saml/acs`), `LEXIGRID_SAML_IDP_ENTITY_ID`, `LEXIGRID_SAML_IDP_SSO_URL`, and `LEXIGRID_SAML_IDP_CERT` (trusted IdP signing certificate). Set `LEXIGRID_PUBLIC_HOST`. Install `python3-saml` and native XML signature dependencies in the container. The IdP must sign both responses and assertions. Pre-provision accounts and bind each IdP NameID using `LEXIGRID_ADMIN_CONFIRM=YES python -m app.admin_cli bind-saml --tenant-id UUID --email user@example.org --subject NAMEID`. Login starts at `/api/auth/saml/start?tenant_id=UUID`. SAML response IDs are stored to prevent reuse. Confirm signed assertion, expiry, audience, ACS URL, InResponseTo, NameID, and replay behavior against the actual IdP before production. Browser starts use the nonce-protected same-origin session handoff; direct API starts retain JSON responses. Required MFA is checked against validated assertion contexts. See ACTIVE_DIRECTORY_SSO.md for simultaneous Entra OIDC and AD FS SAML.

Vault Transit encryption

Set `LEXIGRID_KMS_PROVIDER=vault`, `LEXIGRID_VAULT_ADDR=https://vault.example`, `LEXIGRID_VAULT_TOKEN`, `LEXIGRID_VAULT_TRANSIT_MOUNT=transit`, `LEXIGRID_VAULT_TRANSIT_KEY=lexigrid` and optionally `LEXIGRID_VAULT_CA_BUNDLE`. Vault policy must permit `transit/encrypt/lexigrid`, `transit/decrypt/lexigrid`, and `transit/rewrap/lexigrid` as needed. Configure a derived Transit key if context-based tenant separation is required; the evidence API uses tenant/control/record context. Legacy evidence remains readable only with `EVIDENCE_ENCRYPTION_KEY`. Never delete old keys until all legacy evidence is migrated. Rotate Vault keys using approved Vault operations; existing ciphertext can be rewrapped with the provided `rewrap()` adapter. Validate key rotation with actual Vault before production. Use short-lived machine authentication in place of a long-lived token in environment variables.

WORM audit checkpoints

Configure a versioned S3-compatible bucket with Object Lock enabled at bucket creation, Compliance retention, and restricted independent credentials. Set `LEXIGRID_AUDIT_WORM_BUCKET`, `LEXIGRID_ANCHOR_HMAC_KEY`, and optionally `LEXIGRID_S3_ENDPOINT` and `LEXIGRID_AUDIT_RETENTION_DAYS`. Run `python -m app.audit_worm` using a scheduled independently controlled job with owner/privileged audit-read access. The uploader writes and reads back a checkpoint and confirms retention. The deployment must schedule periodic exports and independently verify previous checkpoint chains; this is not automatic yet. Validate object-lock enforcement with the actual storage backend.

Deployment

`Dockerfile` includes Alembic files and scripts for migrations. Set all required secrets in `.env`, use a TLS reverse proxy, and restrict database access. Run `docker compose config`, `docker compose build`, `docker compose up -d`, `docker compose ps`, then execute `python -m app.diagnostics` with the appropriate connection. Run the live PostgreSQL integration suite against a disposable instance. Perform backup/restore and encryption key recovery drills. Record the results of these checks for the target deployment. Real customer IdP, external Vault/Conjur, independent object retention, TLS/SIEM and HA qualification remain open; synthetic mocks are not evidence of those external deployments.

Administration and GUI

The browser interface includes dashboard, risks, controls, frameworks, policies, approvals, remediation, vendors, services, losses, audit, security, administration, and exports. The Administration page provisions tenant users and displays health; Exports downloads authenticated tenant-scoped risk and audit reports. Federation binding and privileged password resets remain owner-CLI operations.

Local evidence encryption accepts the existing 32-byte key encoded as standard base64 or as 64 hexadecimal characters, including the format emitted by the installers. Representations of the same key bytes read the same ciphertext. Preserve the original key when restoring data.

LexiGrid Logging Configuration

Configuration: `config/logging.json` (preserved on upgrade). The application loads this file at startup.

Example

```
{
  "version": 1,
  "directory": "logs",
  "max_bytes": 10485760,
  "backup_count": 10,
  "system": {"file": "system.jsonl", "level": "INFO"},
  "operations": {"file": "operations.jsonl", "level": "INFO"},
  "central": {
    "enabled": false, "type": "syslog_tls", "host": "127.0.0.1",
    "port": 6514, "ca_file": "/path/to/ca.pem"
  }
}
```

- `logs/system.jsonl`: application startup/shutdown, HTTP success/error and timing.

- `logs/operations.jsonl`: committed operations and authentication failures; successful business actions are written after DB commit.

- For centralized forwarding, enable `central.enabled`, select `syslog_udp`, `syslog_tcp`, or `syslog_tls`, and supply collector host/port. For TLS, configure a CA certificate.

- Restart the service after editing. Invalid configuration prevents startup.

- For Docker the config file is bind-mounted read-only and logs use a persistent named volume.

- Native runtime startup diagnostics also appear in `run/native.log`.

- Syslog UDP and TCP are supported, but encrypted TLS is preferred. Vendor-specific APIs/HEC are not implemented.

- Log transport is best effort; use collector acknowledgement/monitoring for critical deployments.

- Avoid secrets in risk descriptions and notes, as user-supplied content can appear in business audit details.

Correlated requests and import outcomes

Each HTTP response includes a server-generated X-Request-ID. System request events and operations transaction events include method, route, status, duration and verified actor/tenant metadata when authentication succeeds. A valid X-LexiGrid-Operation-ID groups the browser review and import attempt; it is correlation metadata, not proof of identity.

Operations events distinguish document extraction, import requested/completed, database commit/rollback, CSV validation, and browser selection/confirmation/cancellation errors. Import references shown in the browser can be searched in the configured JSON logs. Business success events are emitted after commit; a rollback discards queued success events. Ordinary HTTP success is a response outcome and does not itself claim a database commit.

The browser diagnostic endpoint accepts only bounded event names, record types, counts and source-line numbers. It does not accept exception messages, document text, passwords or arbitrary payloads. Validation responses omit submitted inputs; unexpected server failures return a safe request reference. Server exception logs retain exception class and code locations without raw exception values, SQL parameters, credentials or uploaded contents. Existing application audit records and their integrity protection are retained.